MODULE 12 · DOMAIN 2 - CONFIGURATION MANAGEMENT AND IAC

Organizations and Control Tower

SCPs, RCPs and declarative policies, delegated administration and resource sharing, Control Tower controls, and the ways to vend and customise accounts.

DOMAIN 2 of 6 EXAM WEIGHT 17% MODULE 12 of 34

admin@sthithapragna.com

Organisation policies **never grant** anything. They set **ceilings**. Accounts and resources grant access underneath them.

AWS Organizations, in one slide

- A **management account** owns the organisation; **member accounts** sit in a tree of **OUs**.
- **All features** mode enables policies; consolidated billing alone does not.
- Policies attached to the root or an OU are **inherited** by everything beneath.
- Services integrate through **trusted access**, and many allow a **delegated administrator** account.

> ON THE EXAM
>
> Keep the management account nearly empty: no workloads, few users, delegated administrators doing the daily work.

The policy types in an organisation

POLICY	SETS A CEILING ON	TYPICAL USE
Service control policy	What principals in member accounts can do	Deny Regions, protect CloudTrail
Resource control policy	What can be done to resources in member accounts	No access from outside the organisation
Declarative policy	A service's configuration	IMDSv2 by default; block public AMIs
Tag policy	Tag keys and allowed values	Consistent cost allocation tags
Backup policy	AWS Backup plans across accounts	Organisation-wide backups
AI services opt-out	Use of content to improve AI services	Data governance

ON THE EXAM

SCPs and RCPs are authorisation policies. The rest are management policies that shape configuration.

How an SCP decision is made

01
Root
An Allow must be present here.

02
Each OU
An Allow must be present at every level.

03
The account
And here, too.

04
Any Deny
An explicit Deny anywhere wins outright.

05
Then IAM
Identity and resource policies grant within the ceiling.

ON THE EXAM

FullAWSAccess is attached everywhere by default. Remove it from one OU and everything below it is denied.

SCP exceptions to memorise

- SCPs **do not** affect the **management account**.
- SCPs **do not** affect **service-linked roles**.
- SCPs **do** affect the **root user** of member accounts.
- SCPs never grant, so an SCP 'allowing' a service gives nobody access by itself.

> ON THE EXAM
>
> A guardrail that 'does not work' in the management account is working as designed.

SCPs now speak the full IAM language

- Since **19 September 2025**: conditions and specific resource ARNs in **Allow** statements.
- **NotAction** with Allow, and **NotResource** in Allow and Deny.
- Wildcards anywhere in an action, such as s3:*Object*.
- Existing SCPs keep working. AWS still recommends explicit Deny statements for guardrails.

> ON THE EXAM
>
> Older material says SCP Allow statements cannot use conditions. That stopped being true in September 2025.

A Region guardrail that does not break global services

```
1 { "Effect": "Deny",
2   "NotAction": [ "iam:*", "organizations:*", "sts:*", "route53:*",
3                  "cloudfront:*", "support:*", "budgets:*" ],
4   "Resource": "*",
5   "Condition": {
6     "StringNotEquals": { "aws:RequestedRegion": ["eu-west-1", "eu-central-1"] },
7     "ArnNotLike": { "aws:PrincipalArn": "arn:aws:iam::*:role/BreakGlass" } } }
```

2-3 Global services send requests to us-east-1, so they must be exempt.

7 A break-glass role is excluded, so an emergency is not blocked.

ON THE EXAM

Region SCP breaks IAM or CloudFront: global services were not exempted with NotAction.

SCP or RCP?

RESOURCE CONTROL POLICY

Protects your data

- Caps what may be done to your resources
- Overrides a permissive resource policy
- Blocks access from outside the organisation
- Launched November 2024

SERVICE CONTROL POLICY

Limits your people

- Caps what your principals may do
- Cannot limit principals outside the organisation
- Restricts Regions, services, actions
- The long-established guardrail

THE TIEBREAKER

Who is acting? Your engineers: an SCP. Someone outside reaching your data: an RCP.

Resource control policies

- Launched with S3, STS, KMS, SQS and Secrets Manager; now more than two dozen services.
- A data perimeter: deny access unless aws:PrincipalOrgID matches your organisation.
- **RCPFullAWSAccess** is attached by default, as FullAWSAccess is for SCPs.
- They do not affect resources in the management account.

> ON THE EXAM
>
> A bucket policy granting a named external account is not 'public', so Block Public Access permits it. An RCP does not.

Declarative policies

- Enforce a **desired configuration** for EC2, EBS and VPC, rather than a permission.
- Examples: IMDSv2 defaults, VPC Block Public Access, blocking public AMIs and snapshots, allowed AMIs.
- Maintained even as the service adds new APIs, and for accounts that join later.
- An **account status report** shows current values before you enforce.

> ON THE EXAM
>
> An SCP must enumerate every API that could change a setting. A declarative policy just sets it.

Which organisation policy?

REQUIREMENT	POLICY
No one may stop CloudTrail or leave the organisation	SCP
No principal outside the organisation may read our data	RCP
Every instance, now and in future accounts, uses IMDSv2	Declarative policy
Cost-centre tags use one of five approved values	Tag policy
Every account follows the same backup plan	Backup policy

ON THE EXAM

Read the subject of the sentence: a person acting, a resource being reached, a setting, a tag, a backup.

Delegated administrators

- A member account runs a service for the whole organisation: GuardDuty, Security Hub, Config, Macie, StackSets and more.
- Registered **per service**. Delegating one service delegates nothing else.
- Some actions, such as creating accounts, still need the management account.
- Typical layout: a security tooling account administers the security services.

> ON THE EXAM
>
> Security team must manage detection for every account without using the management account: delegated administrator.

Sharing resources with AWS RAM

- **AWS RAM** shares resources such as VPC subnets, Transit Gateways and Route 53 Resolver rules.
- With sharing enabled for Organizations, shares to OUs need **no invitations**.
- Shared subnets let workload accounts launch into centrally managed networks.
- Advanced-tier Parameter Store parameters can also be shared through RAM.

> ON THE EXAM
>
> Central networking, workloads in their own accounts, no peering: share the subnets with RAM.

AWS Control Tower

- Builds a governed **landing zone** on Organizations: log archive and audit accounts, Identity Center, baselines.
- Applies **controls** to OUs and reports **drift** from them.
- **Landing zone 4.0** (November 2025) makes service integrations optional.
- A **controls-only** experience now offers managed controls without a full landing zone.

> ON THE EXAM
>
> Many accounts, governed consistently from day one, least effort: Control Tower.

Three behaviours of control

BEHAVIOUR	IMPLEMENTED AS	ACTS
Preventive	SCPs, RCPs, declarative policies	Blocks the API call
Proactive	CloudFormation Hooks	Blocks the stack before resources exist
Detective	AWS Config rules	Reports non-compliance after it happens

ON THE EXAM

Guidance levels: mandatory, strongly recommended, elective. Controls are enabled per OU.

Vending and customising accounts

TOOL	HOW IT WORKS	CHOOSE IT WHEN
Account Factory	Service Catalog product for new accounts	Simple, console-driven vending
Account Factory Customization	Blueprints applied as accounts are made	A few standard account types
Customizations for Control Tower	Pipeline: CloudFormation and SCPs per OU, from a manifest	CloudFormation shops, Git-managed
Account Factory for Terraform	GitOps: account requests and customisations in Terraform	Terraform shops

ON THE EXAM

Same need, different language: CfCT for CloudFormation, AFT for Terraform.

Hooking into the account lifecycle

- Control Tower emits **lifecycle events**, such as CreateManagedAccount, to EventBridge.
- Rules on those events can start follow-up automation for each new account.
- **Registering** an existing OU enrols its accounts into Control Tower governance.
- Changing managed resources outside Control Tower causes drift that must be repaired.

> ON THE EXAM
>
> Existing accounts need the same governance as new ones: register their OU, rather than recreating accounts.

A company attaches an SCP to its Workloads OU that denies every action when aws:RequestedRegion is not eu-west-1 or eu-central-1.

Since then, engineers in those accounts cannot create IAM roles or update CloudFront distributions, even though their IAM policies allow it.

How should the DevOps engineer fix the SCP?

A Add Allow statements for IAM and CloudFront to the engineers' IAM policies

B Attach FullAWSAccess directly to each account

C Rewrite the Deny with NotAction, exempting global services such as IAM, CloudFront, STS and Route 53

D Move the accounts from the Workloads OU to the root

◆ PAUSE AND DECIDE

How should the DevOps engineer fix the SCP?

A More IAM Allows

An explicit Deny in an SCP beats any Allow. The engineers already had permission.

B FullAWSAccess on accounts

Allows cannot override an explicit Deny either. Nothing changes.

C NotAction for global services

Global services use us-east-1, so the Region Deny caught them. Exempting them keeps the guardrail.

D Move to the root

Removes the guardrail entirely for those accounts.

THE SIGNAL

Region guardrail breaks IAM or CloudFront: the global services were not exempted.

> Teams in member accounts write their own S3 bucket policies and KMS key policies. An audit finds several that grant access to AWS accounts outside the company's organisation.
>
> The security team must ensure no principal outside the organisation can access S3 buckets or KMS keys in member accounts, whatever those policies say, with the least operational overhead.

Which solution meets these requirements?

A An SCP denying S3 and KMS actions by principals outside the organisation

B Enable S3 Block Public Access on every account

C An AWS Config rule with a Lambda remediation that removes external statements

D An RCP denying S3 and KMS access unless aws:PrincipalOrgID matches the organisation

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A SCP on outside principals

SCPs only limit principals inside the organisation. Outsiders are untouched.

B Block Public Access

A grant to a named external account is not public. It still works. And it does nothing for KMS.

C Config and remediation

Detects and repairs after exposure, with custom code. Not 'whatever those policies say'.

D RCP on aws:PrincipalOrgID

Caps what can be done to the resources, overriding any permissive policy, centrally.

THE SIGNAL

Outsiders reaching your data despite member-account policies: an RCP. SCPs cannot touch outside principals.

A company requires every EC2 instance in every account to use IMDSv2. This must apply to accounts created in the future, and keep working as EC2 adds new APIs.

The company wants the least operational overhead, and a way to see current settings across accounts before enforcing.

Which solution meets these requirements?

A. An EC2 declarative policy enforcing IMDSv2 defaults, attached at the organisation root, after reviewing the account status report

B. An SCP denying ec2:RunInstances unless ec2:MetadataHttpTokens is required

C. An AWS Config rule with automatic remediation that modifies non-compliant instances

D. A Lambda function triggered by CloudTrail events that stops non-compliant instances

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A Declarative policy, after the status report

Sets the configuration itself, survives new APIs, covers future accounts, and the report shows readiness first.

B SCP on RunInstances

Works today, but must enumerate every API that could change the setting. Fails 'as EC2 adds APIs'.

C Config with remediation

Detects after launch, then repairs. More moving parts, and not preventive.

D Lambda on CloudTrail

Custom code reacting after the fact, and stopping instances disrupts workloads.

THE SIGNAL

'Keep working as the service adds new APIs' is the declarative policy's defining promise.

> A company's security team works in a dedicated security tooling account. It must enable and manage Amazon GuardDuty and AWS Security Hub for every account in the organisation.
>
> Company policy forbids the security team from working in the management account.

What should the DevOps engineer do?

A. Give the security team an administrator role in the management account

B. Register the security tooling account as delegated administrator for GuardDuty and for Security Hub

C. Create a cross-account role in every member account for the security team

D. Move the security tooling account to the root of the organisation

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Admin in management

Directly violates the stated policy.

B Delegated administrator, per service

The tooling account manages both services organisation-wide. Registered once for each service.

C Cross-account roles everywhere

Works account by account, but new accounts need new roles, and it is not how the services organise.

D Move to the root

Where an account sits in the tree grants no administrative rights.

THE SIGNAL

Run a service for the whole organisation from a member account: delegated administrator, registered for each service.

A central networking team owns a VPC with carefully controlled subnets, routing and firewalls. Application teams work in their own accounts in the Workloads OU.

Application teams must launch resources directly into the central subnets, without VPC peering, and new accounts in the OU should get access automatically.

Which solution meets these requirements with the LEAST operational overhead?

A. A VPC peering connection from each application account's VPC to the central VPC

B. Transit Gateway attachments from each application account

C. A StackSet that creates an identical VPC in every application account

D. Share the subnets with the Workloads OU through AWS RAM, with sharing enabled for Organizations

◆ PAUSE AND DECIDE

Which solution meets these requirements with the LEAST operational overhead?

A Peering per account

Explicitly ruled out, and the teams would still launch into their own VPCs.

B Transit Gateway

Connects separate VPCs. Teams still would not launch into the central subnets.

C Identical VPCs

Many VPCs to govern, rather than one central network.

D RAM share to the OU

Teams launch straight into central subnets; new accounts in the OU are included automatically.

THE SIGNAL

'Launch into central subnets' is subnet sharing. Peering and Transit Gateway connect separate networks.

A company uses AWS Control Tower and has standardised on Terraform for all infrastructure. Account requests must be made as code, through pull requests in Git.

Each new account must automatically receive account-specific customisations, also written in Terraform.

Which solution meets these requirements?

A Customizations for AWS Control Tower, with a manifest mapping templates to OUs

B Create accounts in Account Factory by hand, then apply Terraform afterwards

C Account Factory for Terraform

D A service-managed StackSet with automatic deployment

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A **CfCT**

Git-driven and automatic, but its templates are CloudFormation. The wrong language here.

B **Manual Account Factory**

Requests are not code, and customisation is not automatic.

C **Account Factory for Terraform**

Account requests and customisations as Terraform, through a GitOps workflow.

D **StackSet**

Deploys CloudFormation, and creates no accounts.

THE SIGNAL

Same need, different language: Terraform points to AFT, CloudFormation to CfCT.

> A platform team uses Control Tower. It wants CloudFormation deployments in the Workloads OU to be stopped before an S3 bucket without versioning is created.
>
> The team does not want to write or maintain any custom rules.

What should the platform team do?

A Enable the detective control that checks S3 bucket versioning on the OU

B Enable the managed proactive control that requires S3 bucket versioning on the OU

C Attach an SCP that denies s3:CreateBucket

D Write a Guard rule and deploy it as a Hook in every account

◆ PAUSE AND DECIDE

What should the platform team do?

A **Detective control**

A Config rule reports the bucket after it exists. Not 'before it is created'.

B **Managed proactive control**

Implemented as a CloudFormation Hook. Stops the stack before the bucket exists, with no rules to write.

C **SCP on CreateBucket**

Blocks every bucket. Versioning is set by a separate call, so an SCP cannot test for it.

D **Custom Guard Hook**

Would work, but it is exactly the custom rule the team refused to maintain.

THE SIGNAL

Before creation, through CloudFormation, no custom rules: a managed proactive control.

A company set up Control Tower last year. Twelve older accounts sit in an OU called Legacy, which Control Tower does not govern.

The company wants those twelve accounts to receive the same controls and baselines as accounts created through Account Factory, with the least effort and no downtime.

What should the DevOps engineer do?

A Register the Legacy OU with Control Tower so its accounts are enrolled

B Create twelve new accounts through Account Factory and migrate the workloads

C Apply matching SCPs and Config rules to the Legacy OU by hand

D Deploy the baselines to the twelve accounts with a StackSet

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Register the OU

Enrols the existing accounts in place, with the same baselines and controls, and ongoing drift detection.

B New accounts and migrate

Enormous effort and risk, for something enrolment does in place.

C Copy controls by hand

Looks similar, but Control Tower neither manages nor reports drift on it.

D StackSet baselines

Deploys some resources, but not Control Tower's controls or governance.

THE SIGNAL

Existing accounts, same governance, in place: register the OU. Recreating accounts is almost never the answer.

Module 12 in five lines

- Organisation policies set ceilings; they never grant. An explicit Deny anywhere wins.
- SCPs: your principals, not the management account, not service-linked roles. Full IAM language since September 2025.
- RCPs: your resources, against outsiders. Declarative policies: configuration that survives new APIs.
- Delegated administrators per service; RAM shares subnets across the organisation.
- Control Tower controls: preventive, proactive, detective. CfCT for CloudFormation, AFT for Terraform.

> ON THE EXAM
>
> Next, module 13: Systems Manager fleet automation, AppConfig, and life after OpsWorks.